

# HRMS v2.0 Migration - TO DO List

Living document - updated as tasks complete. Source of truth for the migration's remaining work.

## Milestone status

|                    |                                                                    |
|--------------------|--------------------------------------------------------------------|
| Completed tasks    | 28 / 30                                                            |
| Current branch     | main @ 63d067a                                                     |
| Next task          | Phase 5: final cutover to public, then Phase 6 DuckDB decommission |
| Follow-up progress | 8 / 8 done                                                         |
| Phase 0-1 progress | 3 / 3 done                                                         |
| Phase 2 progress   | 2 / 2 done                                                         |
| Phase 3a progress  | 3 / 3 done                                                         |
| Phase 3b progress  | 9 / 9 done                                                         |
| Phase 4 progress   | 3 / 3 done                                                         |
| Phase 5 progress   | 0 / 1 done                                                         |
| Phase 6 progress   | 0 / 1 done                                                         |

## TO DO / status by phase

### Phase 0-1 (3/3 done)

|      |                                                                                                                                          |
|------|------------------------------------------------------------------------------------------------------------------------------------------|
| DONE | <b>Freeze the v1.0 DuckDB schema; inventory tables for ETL</b><br>Schema freeze note in docs/MIGRATION.md (08f7e40)                      |
| DONE | <b>Build v2.0 target schema (db/postgres_schema.sql + Alembic baseline)</b><br>50-table public schema, CC-01..CC-16 documented (08f7e40) |
| DONE | <b>One-time DuckDB -&gt; PostgreSQL ETL with reconciliation</b><br>hrms DB seeded; counts reconciled (08f7e40)                           |

### Phase 2 (2/2 done)

|      |                                                                                                                                   |
|------|-----------------------------------------------------------------------------------------------------------------------------------|
| DONE | <b>DuckDB-&gt;psycpg adapter (db_backend.py): translate/strftime/autocommit</b><br>App runs on PostgreSQL legacy schema (b9164f2) |
| DONE | <b>Unit + browser suites green on PostgreSQL (legacy schema preserved)</b><br>29/29 unit, 15/15 Playwright (b9164f2)              |

### Phase 3a (3/3 done)

|      |                                                                                             |
|------|---------------------------------------------------------------------------------------------|
| DONE | <b>Argon2id password hashing; legacy bcrypt re-hashed on login</b><br>security.py (98563ee) |
| DONE | <b>Global CSRF enforcement (fetch wrapper + csrf_token field + token API)</b><br>98563ee    |
| DONE | <b>Server-side Redis sessions (REDIS_URL opt-in) + login rate limiting</b><br>98563ee       |

### Phase 3b (9/9 done)

|      |                                                                                                                                                      |
|------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| DONE | <b>CC-01 identity rule enforced: scripts/check_cc_rules.py + PG-gated test</b><br>46 identity + 4 natural keys, sequences ahead of data (acb5219)    |
| DONE | <b>Public-flip readiness probe (scripts/probe_public_flip.py)</b><br>GET + write-flow matrix against a throwaway public DB (acb5219)                 |
| DONE | <b>Boolean adapter compat: predicates, INSERT params, naive datetime round-trip</b><br>Inert on legacy (zero boolean cols); PG-gated tests (21480fe) |

|      |                                                                                                                                                                                                                                                                             |
|------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DONE | <b>Write-flow probe + salary_structures seed data fix (CC-05)</b><br>11/11 core write flows green on public (21480fe)                                                                                                                                                       |
| DONE | <b>CC-09 transactional outbox (outbox.py + scheduler + admin endpoints)</b><br>Atomic business-write + event; backoff -> dead-letter (7e52f88)                                                                                                                              |
| DONE | <b>CC-07 idempotency: @idempotent decorator + idempotency_keys wired for keyed POST retries</b><br>Replay-without-duplicate, 409 on body reuse, claim released on failure; 6 unit tests green on every stack; probe replays on pure v2.0 JSONB                              |
| DONE | <b>Service-layer rewrite inc 1: expanded audit_log (actor/entity/entity_id/before/after/request_id, CC-13) + notifications.category (FR-NOT-03)</b><br>8ff66bc; +6 unit tests; DuckDB 46 green                                                                              |
| DONE | <b>Service-layer rewrite inc 2: shift_assignments replaces users.shift_start/shift_end (FR-ATT-17); init_db no longer mutates v2.0 public.users</b><br>get_shift/set_shift helpers reroute ~10 touch points; user CRUD + seed via set_shift; public probe 42/42 write flows |
| DONE | <b>Extend probe write section: forgot-password, payroll bank-file/TDS, ticket/ATS + verify against a clean public schema</b><br>Clean hrms_probe re-run: 94/94 GET + 42/42 write flows, including attendance, payroll, and lifecycle paths; all seed-time writes green      |

## Phase 4 (3/3 done)

|      |                                                                                                                                                                 |
|------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DONE | <b>Attendance finalisation job (FR-JOB-01)</b><br>7 acceptance tests + nightly scheduler + regularization recompute; clean public probe 94/94 GET + 42/42 write |
| DONE | <b>Maker-checker payroll (FR-PAY-06)</b><br>Strict state machine + approval trail + Finance/Admin UI; clean public probe 94/94 GET + 42/42 write                |
| DONE | <b>Corrected ATS / onboarding / offboarding flows</b><br>FR-ATS/FR-ONB/FR-OFF acceptance suite + 94/42 public probe                                             |

## Phase 5 (0/1 done)

|                |                                                                                                                                                                                                                |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IN<br>PROGRESS | <b>Final cutover: flip APP_DB_SCHEMA to public, retire legacy</b><br>Disposable rehearsal passed ETL/preflight/94-42 probe/authenticated smoke/CC-01 sequence check; maintenance-window traffic switch pending |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## Phase 6 (0/1 done)

|         |                                                                                |
|---------|--------------------------------------------------------------------------------|
| PENDING | <b>Decommission DuckDB runtime</b><br>Out of the ETL blueprint; tracked in SRS |
|---------|--------------------------------------------------------------------------------|

## Follow-up (8/8 done)

|      |                                                                                                                                                                                                                                                                        |
|------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DONE | <b>FR-USR archive/restore and session revocation</b><br>Hard delete replaced with retained archive/restore; admin UI and cross-backend tests updated                                                                                                                   |
| DONE | <b>FR-USR directory contract (bounded pagination, sorting, validation)</b><br>per_page capped at 200, allow-listed sorting, EMP/email/role/departement validation, case-insensitive uniqueness, partial PUT with role-change audit, CSV import under the same contract |
| DONE | <b>FR-USR-09 permission policy (policy.py matrix + permissions API/UI)</b><br>27-module role matrix, deny-beats-allow overrides, full-replace PUT with audit diff, anti-lockout guard, admin permissions modal                                                         |
| DONE | <b>FR-USR-15 policy enforcement wiring (decorators + navbar)</b><br>Role gates narrowed by policy.can(); navbar derived from the same gate/module tags; department grant modelled; nav/API drift tests                                                                 |
| DONE | <b>FR-USR-15 inline scope checks + audited pii_reveal</b><br>No handler branches on the session role copy; can_view_all is the CC-11 scope half; PII reveal route audited per cross-employee read                                                                      |
| DONE | <b>FR-LEA-06/08 policy-derived leave balances</b><br>Entitlement derived from the effective leave_policy_assignments; reserved ledger enforced; audited policy API + admin modal                                                                                       |

|      |                                                                                                                                                                                                                       |
|------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DONE | <b>FR-USR-04 background bulk import jobs</b><br>202 + queued import_jobs, single-claim dispatcher, progress/history/cancel, upload deleted, audited completion                                                        |
| DONE | <b>FR-USR two-person anonymisation</b><br>proposed -> confirmed by a different approver -> applied; archived-only; dry run; value-scrubbed audit history; required salt; trade-offs recorded in docs/ANONYMISATION.md |

## Test & readiness gates

| Gate                                             | Stack                        | Current result                                                                                                           |
|--------------------------------------------------|------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Unit suite (tests/test_app.py)                   | DuckDB                       | 152 passed, 6 skipped (PG-gated compatibility/public tests)                                                              |
| Unit suite (tests/test_app.py)                   | PostgreSQL                   | 157 passed, 1 skipped (public-only shift test)                                                                           |
| Unit suite (tests/test_app.py)                   | PostgreSQL + Redis           | 157 passed, 1 skipped                                                                                                    |
| Browser suite (tests/test_playwright.py)         | DuckDB                       | 21 passed (single-threaded, scheduler off)                                                                               |
| Browser suite (tests/test_playwright.py)         | PostgreSQL                   | 21 passed                                                                                                                |
| CC-01 rule checker (scripts/check_cc_rules.py)   | hrms_probe (public)          | OK - every surrogate key is identity, sequences ahead of data                                                            |
| CI PostgreSQL job                                | postgres:17 + redis services | Unit suite on legacy (with and without Redis), browser suite, and the preflight/CC-01/probe gates on a clean v2.0 target |
| Public-flip probe (scripts/probe_public_flip.py) | hrms_probe (public)          | 97/97 GET + 44/44 write flows; lifecycle + permission + import paths included                                            |
| Cutover preflight (scripts/cutover_preflight.py) | hrms (public)                | Ready: head 0005, identity/sequence rules, required tables, and delta report generated                                   |
| Disposable Phase 5 rehearsal                     | hrms_cutover_rehearsal       | ETL Phase-1/2 + CC-05 cleanup + preflight + 94/42 probe + authenticated smoke + CC-01 sequence check passed              |

## Update log (newest first)

|                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>2026-09-29</b> | FR-AUTH-10 password policy: a 10-character minimum (Appendix A-01 calls 6 a defect) plus a breach-corpus check, enforced wherever a password is set, with no complexity rules and no expiry by design per NIST SP 800-63B - a test parses the module's AST to keep them out. The corpus is offline by default (a check that fails when the network is down does not exist) with the HIBP k-anonymity range query behind HIBP_URL. Leet variants and known-password-plus-suffix are caught, and the rejection message is generic so it is not an oracle for confirming a guess. The shared default of pass123 is gone: a user created without a password now gets a generated compliant one returned once. Matrix is now 49 IMPLEMENTED / 43 PARTIAL / 11 NOT_STARTED / 1 RETIRED.                                                                                                                                                                                                                                                                                                                                                                               |
| <b>2026-09-29</b> | FR-EXP-03 expense claim state machine: following the traceability matrix into expenses_api found three defects - an admin could approve a claim they had filed themselves, a claim could jump Pending to Paid with no approval, and a paid claim could be moved back to Pending - plus the CC-10 impersonation hole where emp_id came from the request body. expenses.py owns a strict transition table, blocks self-approval, gives Paid to Finance/Admin only (Appendix A-11), requires a rejection reason, and writes every transition as a conditional UPDATE with a before/after audit. The gate was the other half: admin_required excluded both the claim owner's manager and Finance, making Approved to Paid unreachable by the role the SRS names, so a new expense_actor_required gate admits manager, HR, Finance and Admin, and Finance now holds the expenses module. The matrix also corrected itself: the previous claim that FR-DIC-02 validated the file extension rather than the content was wrong - the upload route does sniff the magic number and reject EICAR. Matrix is now 48 IMPLEMENTED / 43 PARTIAL / 12 NOT_STARTED / 1 RETIRED. |
| <b>2026-09-29</b> | SRS traceability matrix: traceability.py maps all 104 SRS requirements to the routes that implement them, and docs/TRACEABILITY.md is generated from it. Four tests keep it honest - the id set must match the SRS, every route named must exist in the live url_map, an IMPLEMENTED row with no route must explain itself, and a PARTIAL row must name its gap. Verdicts: 47 IMPLEMENTED, 44 PARTIAL, 12 NOT_STARTED, 1 RETIRED. The largest gap found is FR-AUTH-11 MFA: mfa_credentials exists in the canonical schema with an encrypted secret and no code reads or writes it. Same shape for approval_delegations, notification_preferences and holiday_opts. Two security PARTIALs verified by reading the handlers: FR-DIC-02 validates the file extension rather than the content (no malware scan, a renamed .exe passes), and FR-EXP-03 has no self-approval block so an employee can approve their own claim.                                                                                                                                                                                                                                        |

|                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>2026-09-29</b> | Server-side session coverage: CI re-ran the whole unit suite with REDIS_URL set, but no test in the suite referred to the session store, so the step passed identically whether the backend was Redis or the app had silently fallen back to signed cookies - which is what the first run of the new tests found. tests/test_redis_sessions.py is now its own pytest process (the backend is chosen when app is imported) and asserts the opaque cookie, the Redis payload and TTL, session persistence, logout deleting the key, block and archive revoking the session while an unrelated one survives, re-blocking after an unblock, CSRF still enforced, and both fallback paths. The duplicate 122-test CI step is replaced by these 10 tests.                                                                                                                                                                       |
| <b>2026-09-29</b> | FR-LEA-08 monthly leave accrual: monthly_leave_grants was in the canonical target and unwritten, so an accrual rate was collapsed into a flat annual ceiling at assignment time. The rate-driven entitlement is now what the employee has earned so far (floor(rate x months elapsed) across the months the assignment was in force), posted one row per elapsed month by a monthly cron job, POST /api/accrual/run, or the Accrue now button in the leave-policy modal - all three idempotent. The entitlement is derived and the grant is the record, so a missed run cannot leave anybody with no leave; granted_by is NULL because it is a foreign key to users(emp_id) in v2.0. entitlement_days now takes the balance year, and a year the policy never reached keeps the published default. DuckDB 126 passed / 6 skipped; PostgreSQL 131 passed / 1 skipped; Playwright 21 passed; probe 97/97 GET + 45/45 write. |
| <b>2026-09-28</b> | FR-USR-15 PII completion: policy.PII_FIELDS is now a per-entity map, so a candidate's email and phone are withheld from /api/candidates and /api/offers unless the actor holds pii_reveal, each record carries pii_revealed, and a permitted read writes one PII_REVEAL audit row. A candidate's name is never withheld (a recruiter must know whose record they are editing) and dependents are classified but have no cross-employee read path. Also made the scheduler registration testable without starting a scheduler thread, which is what made the DuckDB unit suite intermittently fail. DuckDB 121 passed / 6 skipped; PostgreSQL 126 passed / 1 skipped; Playwright 21 passed; probe 97/97 GET + 44/44 write.                                                                                                                                                                                                 |
| <b>2026-09-28</b> | FR-USR two-person anonymisation: propose then confirm-by-a-different-approver, applied by the system, archived accounts only, with a dry-run plan, a required ANONYMISATION_SALT, dependents erased and the statutory rows kept, and the subject's own audit history scrubbed by value substitution (including historical values, so a rename cannot leave the old name behind). Trade-offs taken on the operator's behalf - keeping emp_id as the seven-year join key and leaving free text - are recorded in docs/ANONYMISATION.md. Also added an on-demand import run route and made the DuckDB browser fixture scheduler-free. DuckDB 116 passed / 6 skipped; PostgreSQL 121 passed / 1 skipped; Playwright 21 passed; probe 97/97 GET + 44/44 write.                                                                                                                                                                 |
| <b>2026-09-28</b> | FR-USR-04 background import jobs: POST /api/users/import now returns 202 with a queued job (5 MB / 5000-row caps, streaming validation, idempotent retry), a dispatcher claims one job per tick with a conditional status transition so several workers cannot collide, progress is published every 25 rows, the outcome is audited and the stored upload is deleted when the job settles. Added the import_jobs table via revision 0004_import_jobs plus the compat DDL, job status/history/cancel routes and a polling UI. Also fixed audit_log, which silently dropped every scheduler-thread write (the nightly ACCESS_REVOKED rows), and made the global rate limit overridable so a full suite no longer trips it mid-run. DuckDB 111 passed / 6 skipped; PostgreSQL 116 passed / 1 skipped; Playwright 20 passed; probe 96/96 GET + 44/44 write.                                                                   |
| <b>2026-09-28</b> | FR-LEA-06/08 policy-derived leave balances: the entitlement now comes from the effective leave_policy_assignments (accrual rate x 12, capped by carry-forward) and falls back to the published defaults, so deriving changes nothing until a policy is assigned. The apply path always enforces (it used to skip employees with no row) and reserves the days while a request is pending, which is the first write to the reserved column and closes the double-spending hole. Added an audited policy API plus an admin modal. Also fixed the intermittent DuckDB browser-suite flake (DuckDB attaches a file once per process, so the dev server runs single-threaded there). DuckDB 107 passed / 6 skipped; PostgreSQL 112 passed / 1 skipped; Playwright 19 passed; probe 94/94 GET + 44/44 write.                                                                                                                    |
| <b>2026-09-28</b> | FR-USR-15 scope + PII: no handler branches on the session role copy any more (test-enforced), the company-wide list split became policy.can_view_all (CC-11 scope), the dashboard variant follows sees_admin_surface(), and pii_reveal is now enforced and audited: GET /api/users//pii is the only cross-employee personal-data read and every such reveal writes a PII_REVEAL audit row. DuckDB 102 passed / 6 skipped; PostgreSQL 107 passed / 1 skipped; Playwright 18 passed; probe 94/94 GET + 44/44 write.                                                                                                                                                                                                                                                                                                                                                                                                         |
| <b>2026-09-28</b> | FR-USR-15 enforcement wiring: the four role gates now narrow with policy.can() (the role/department check stays the outer gate, so an empty override table is a no-op), every gated view is mapped to a module, and the navbar is derived from the same gate/module tags so a link exists only when the route would admit the user. The HR-department grant is modelled explicitly. Drift removed (Finance no longer sees 403ing links, Super Admin sees the admin links) and /admin/leaves is now reachable. DuckDB 97 passed / 6 skipped; PostgreSQL 102 passed / 1 skipped; Playwright 17 passed; probe 94/94 GET + 44/44 write.                                                                                                                                                                                                                                                                                       |

|                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>2026-09-28</b> | FR-USR-09 permission policy implemented: policy.py owns the 27-module role matrix with deny-beats-allow per-user overrides, GET/PUT /api/users//permissions does a full replace with an audit diff and an anti-lockout guard, and the admin user list gained a permissions modal. Empty overrides reproduce the role defaults exactly, so no existing authorization outcome changes; decorator/navbar enforcement is the next slice. DuckDB 90 passed / 6 skipped; PostgreSQL 95 passed / 1 skipped; Playwright 17 passed; public probe 94/94 GET + 44/44 write.                      |
| <b>2026-09-28</b> | FR-USR directory contract implemented: GET /api/users caps per_page at 200 and sorts through an allow-list (400 on invalid input), POST/PUT validate the employee ID, email, role, department and status with case-insensitive uniqueness, PUT became a true partial update with a before/after audit diff, and the CSV import now validates every row and reports skipped rows. Admin UI mirrors the contract; the public probe stays green.                                                                                                                                         |
| <b>2026-09-25</b> | Phase 5 cutover rehearsal completed: frozen-source ETL accepted a missing post-v1.0 payroll_approvals table, reconciled Phase-1/Phase-2 data, applied CC-05 cleanup, stamped head, passed read-only preflight and 94/42 public probe, and kept identity sequences ahead after boot seeds and authenticated GET/write smoke. Traffic switch remains a maintenance-window operation.                                                                                                                                                                                                    |
| <b>2026-09-25</b> | FR-ATS/FR-ONB/FR-OFF corrected lifecycle implemented: guarded ATS state machine, 100% offer splits, atomic accepted-offer conversion, signed pre-boarding tokens and real-file validation, five-step guarded onboarding, parallel offboarding with F&F; maker-checker, and IST LWD access revocation, plus lifecycle hardening (strict split precision, ETL preservation, session revocation, encrypted credential delivery, and document authorization). DuckDB 77 passed / 5 skipped; PostgreSQL 81 passed / 1 skipped; Playwright 16 passed; public probe 94/94 GET + 42/42 write. |
| <b>2026-09-24</b> | FR-PAY-06 maker-checker payroll implemented: Draft → Submitted → Approved → Finalized, Finance/Admin authorization, self-approval rejection, payroll_approvals trail, adjustment-run reference, Finance UI access, and public probe coverage. DuckDB 64 passed / 5 skipped; PostgreSQL 68 passed / 1 skipped; probe 86/86 GET + 30/30 write.                                                                                                                                                                                                                                          |
| <b>2026-09-24</b> | FR-JOB-01 attendance finalisation implemented: nightly per-shift-date classification, employee weekly-off patterns, holiday/leave precedence, transactional attendance_days replacement, calendar output, and public identity-key probe coverage. DuckDB 64 passed / 5 skipped; PostgreSQL 68 passed / 1 skipped; probe 86/86 GET + 30/30 write.                                                                                                                                                                                                                                      |
| <b>2026-09-24</b> | Service-layer rewrite inc 2/3 completed: shift_assignments, explicit v2.0 INSERTs, BOOLEAN UPDATE parameter coercion, and binary payroll bank-file export; the clean public-flip probe is fully green.                                                                                                                                                                                                                                                                                                                                                                                |
| <b>2026-09-23</b> | CC-07 idempotent writes done: @idempotent decorator on 9 POST routes, idempotency_keys DDL + hourly purge, 6 unit tests green (DuckDB 40 / PG 43 / PG+Redis 43), probe replays on pure v2.0 JSONB -> 86/86 GET + 12/12 write. Next: service-layer rewrite.                                                                                                                                                                                                                                                                                                                            |
| <b>2026-09-23</b> | TODO list created. Next task slated: CC-07 idempotency.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |